

# Access Control Policy

Agentic Voice, Inc. — d/b/a MFunding.net | Momentum Funding

|                  |                                                                                      |
|------------------|--------------------------------------------------------------------------------------|
| Document         | Access Control Policy (ACP)                                                          |
| Version          | 1.0                                                                                  |
| Effective Date   | July 28, 2026                                                                        |
| Next Review      | July 28, 2027 (annual) — access reviews quarterly                                    |
| Owner / Approver | Ernesto Lee, Chief Executive Officer & Security Officer                              |
| Parent Document  | Information Security Policy v1.0, §4–§5                                              |
| Applies To       | All personnel, contractors, service integrations, and systems of Agentic Voice, Inc. |

## 1. Purpose & Scope

This Access Control Policy defines how Agentic Voice, Inc. ("the Company") limits access to production assets and sensitive data — in particular the consumer and business financial data (bank transactions, statements, account identifiers, and Plaid access tokens) processed as part of the Company's business-financing operations. It applies to every human account (employees, officers, independent contractors) and every non-human integration (service accounts, API credentials, automation) across the Company's production systems: the application database and storage (Supabase), source control (GitHub), hosting (Netlify), email and productivity (Google Workspace), the CRM (GoHighLevel), and the Plaid dashboard.

## 2. Principles

- **Least privilege.** Every account — human or service — receives the minimum access its function requires, and no more.
- **Deny by default.** Database access is denied unless a row-level security policy explicitly grants it; new tables are created with row-level security enabled.
- **Individual accountability.** Personnel authenticate with individual credentials. Shared logins are prohibited; where a legacy shared credential is discovered it is rotated and converted to individual access.
- **Separation of tiers.** Merchant-facing users can never reach staff functions; staff roles are tiered so operational users cannot reach administrative configuration.

## 3. Role-Based Access Control (RBAC)

Application access is governed by a defined role model enforced in the production database. Every table has row-level security (RLS) enabled, and policies evaluate the caller's role on every query.

| Role                      | Population             | Access granted                                                                                             |
|---------------------------|------------------------|------------------------------------------------------------------------------------------------------------|
| <b>user</b><br>(merchant) | Financing applicants   | Own records only — own application, documents, deal status, and messages. Enforced row-by-row via RLS.     |
| <b>closer</b>             | 1099 sales contractors | Deals assigned to them; deal-scoped actions (e.g., call grading) verified server-side by ownership checks. |
| <b>employee</b>           | Operations staff       | Operational records needed for processing; no administrative configuration.                                |
| <b>admin</b>              | Managers               | Full pipeline, customer, and reporting access; no platform-level settings.                                 |
| <b>super_admin</b>        | Security Officer / CEO | Platform configuration, integrations, lender network, compliance settings.                                 |

Sensitive server-side operations (document access, disposition changes, underwriting runs) are additionally gated by security-definer functions that re-verify the caller's role or record ownership at execution time.

#### 4. Centralized Identity & Authentication

- Application authentication is centralized through **Supabase Auth**; accounts are provisioned and disabled in one place.
- Administrative access to the supporting platforms (Supabase, GitHub, Google Workspace, Netlify, GoHighLevel, Plaid) is controlled through each provider's identity management under accounts owned by the Company.
- **Multi-factor authentication is required** for administrative accounts on the critical systems that store or process consumer financial data (Supabase, GitHub, Google Workspace).
- Credentials and authentication secrets are never stored in source code or shared in plaintext.

#### 5. Non-Human (Service) Authentication

- Server-side integrations authenticate with **bearer tokens (service-role JWTs) over TLS 1.2+**.
- Third-party credentials — including Plaid client secrets and per-item Plaid access tokens — are held in an **encrypted secrets vault** and as protected edge-function secrets, referenced by identifier rather than value.
- All third-party API calls are made from server-side edge functions; credentials and tokens are never delivered to the browser or mobile clients.
- Inbound automation endpoints are gated by shared-secret verification and fail closed on an invalid secret.

#### 6. Provisioning & Deprovisioning

- **Onboarding:** access is granted only to the systems and role level a person's duties require, approved by the Security Officer before provisioning.

- **Role change:** privileges are adjusted to the new function; prior excess access is removed.
- **Offboarding:** upon termination, access is revoked **immediately** — the application role is disabled, and provider accounts (GitHub, Google Workspace, Supabase, GoHighLevel, Netlify, Plaid) are removed or disabled the same day. Any shared or potentially known credentials are rotated.

---

## 7. Periodic Access Reviews

The Security Officer reviews all human and service accounts and their privilege levels **quarterly**, confirming least privilege, removing stale access, and rotating aged credentials. The review is scheduled as a recurring operational task in the Company's work-management system so that execution does not depend on memory; results and any corrective actions are recorded.

---

## 8. Physical Access

The Company operates no physical production infrastructure. Production systems are fully managed cloud services (Supabase — SOC 2 Type II; Netlify; Google), and physical security of those data centers is inherited from those providers. Company endpoints are password-protected, encrypted devices under the control of authorized personnel.

---

## 9. Enforcement & Exceptions

Violations of this Policy may result in access revocation, contract termination, or further action as appropriate. Exceptions require the written approval of the Security Officer, must be time-bound, and are reviewed at the next quarterly access review.

---

Approved and adopted:

---

Ernesto Lee — Chief Executive Officer &  
Security Officer, Agentic Voice, Inc.

---

Date: July 28, 2026